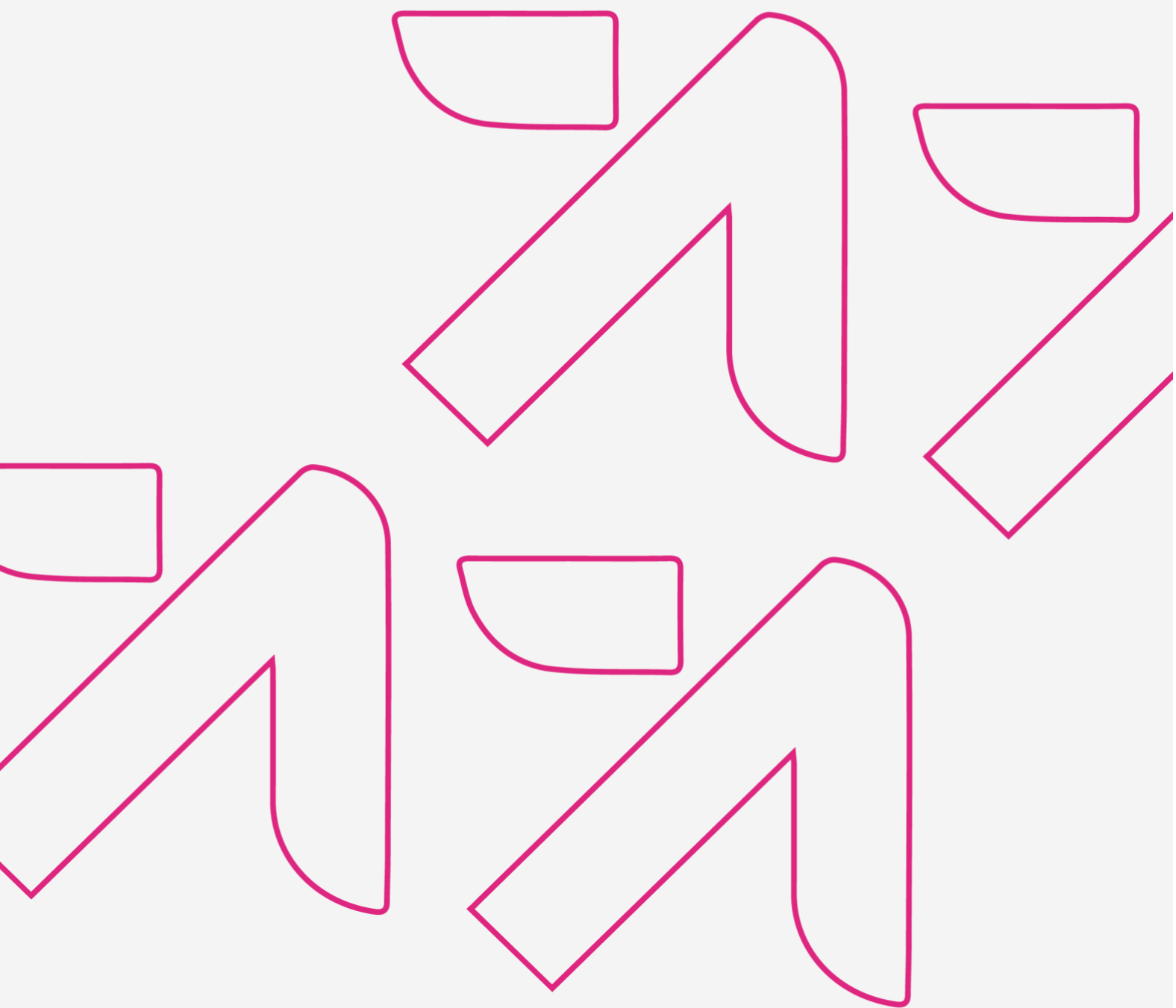




Máster de

Ciberseguridad Hacking Ético

[Módulo Incidentes de Ciberseguridad]

Curso académico 2026/2027 - Edición Presencial

Tema 4. Herramientas y mecanismos para la detección de incidentes

Encaje en el curso 2026/2027: tema 4 del temario oficial; es el único tema del RA2 (analizar incidentes con herramientas de detección y alertas). El laboratorio con Wazuh de este curso es la parte práctica de este tema.

1. Detectar

Detectar es enterarse de que algo va mal lo antes posible y con la información suficiente para actuar. El tiempo que un atacante pasa dentro sin ser visto es el factor que más influye en el daño final.

1.1. De dónde sale la información

- Registros de sistemas operativos, aplicaciones y servicios en la nube.
- Tráfico de red.
- Equipos de usuario y servidores (agentes, EDR).
- Dispositivos de seguridad: cortafuegos, proxy, filtrado de correo.
- Personas: un usuario que avisa sigue siendo una de las mejores fuentes.
- Avisos externos: un proveedor, un CSIRT o un cliente.

1.2. Cuatro resultados posibles

	Hay ataque	No hay ataque
Salta la alerta	Verdadero positivo	Falso positivo
No salta	Falso negativo	Verdadero negativo

El falso negativo es el peligroso, pero el exceso de falsos positivos también hace daño: produce fatiga de alertas y acaba tapando las importantes. Ajustar las reglas es parte del trabajo, no un extra.

2. IDS e IPS

2.1. IDS (sistema de detección de intrusiones)

Observa y avisa, sin intervenir. Hay dos familias según dónde mira:

	NIDS (de red)	HIDS (de equipo)
Qué analiza	Tráfico de un segmento de red	Registros, ficheros y procesos de un equipo
Ve	Escaneos, exploits en tránsito, mando y control	Cambios en ficheros, inicios de sesión, escalada de privilegios
No ve	Lo que va cifrado; lo que ocurre dentro del equipo	Lo que pasa en equipos sin agente
Ejemplos	Suricata, Snort, Zeek	Wazuh, OSSEC

Se complementan: lo razonable es tener ambos.

2.2. Cómo detectan

- **Por firmas:** comparan con patrones de ataques conocidos. Precisos, pero ciegos ante lo nuevo.
- **Por anomalías:** aprenden qué es normal y avisan de lo que se desvía. Detectan lo desconocido a costa de más falsos positivos.

2.3. IPS (sistema de prevención de intrusiones)

Hace lo mismo que un IDS, pero colocado en línea y con capacidad de bloquear. La ventaja es evidente; el riesgo, también: un falso positivo en un IPS corta tráfico legítimo. Por eso las reglas nuevas se prueban primero en modo detección.

2.4. Leer una regla de Suricata

Suricata y Snort comparten casi la misma sintaxis. Una regla tiene cabecera (acción, protocolo, origen y destino) y opciones entre paréntesis:

```
alert tcp any any -> $HOME_NET 22 (msg:"Posible fuerza bruta SSH";  
  flow:to_server; flags:S;  
  threshold:type both, track by_src, count 10, seconds 60;  
  classtype:attempted-admin; sid:1000001; rev:1;)
```

- **alert:** avisa (en modo IPS podría ser drop).
- **tcp any any -> \$HOME_NET 22:** tráfico TCP desde cualquier origen hacia el puerto 22 de nuestra red.
- **threshold:** solo salta si hay 10 intentos desde el mismo origen en 60 segundos.
- **sid:** identificador único de la regla; los propios empiezan en 1000000.

En producción no se escriben todas las reglas a mano: se usan conjuntos mantenidos por la comunidad, como Emerging Threats, y se añaden las propias para lo específico de la organización.

3. SIEM

3.1. Qué hace

Un SIEM (gestión de información y eventos de seguridad) recoge los registros de todas las fuentes, los normaliza a un formato común, los correlaciona y genera alertas y paneles. Su valor está en la correlación: un inicio de sesión fallido no es nada; cincuenta fallos seguidos de un acierto y de la creación de un usuario administrador es un incidente.

3.2. Componentes

1. Recogida: agentes, syslog, API.

2. Normalización y enriquecimiento (decodificadores, geolocalización, inteligencia de amenazas).
3. Correlación: reglas y casos de uso.
4. Alertas y paneles.
5. Almacenamiento y retención.

3.3. Plataformas

Wazuh, Elastic Security y OpenSearch en código abierto; Splunk, Microsoft Sentinel, IBM QRadar y Google Security Operations entre las comerciales.

3.4. Wazuh por dentro

- **Agente:** se instala en cada equipo; recoge registros, vigila la integridad de ficheros y evalúa la configuración.
- **Servidor (manager):** recibe los datos, aplica decodificadores y reglas y genera las alertas.
- **Indexador:** almacena y permite buscar.
- **Panel (dashboard):** la interfaz web.

Cada alerta tiene un identificador de regla, un nivel de 0 a 15 y, cuando procede, la técnica de MITRE ATT&CK asociada. Empezar filtrando por nivel alto y por agente es la forma más rápida de no ahogarse.

3.5. Más allá del SIEM

- **EDR / XDR:** detección y respuesta en el equipo (EDR) o uniendo equipo, red, correo y nube (XDR). Además de avisar, permiten aislar una máquina a distancia.
- **SOAR:** automatiza la respuesta con flujos predefinidos, por ejemplo bloquear una IP en el cortafuegos cuando salta cierta alerta.
- **NDR:** detección centrada en el comportamiento de la red.

4. Ciberinteligencia y OSINT

4.1. Indicadores de compromiso (IoC)

Rastros que delatan un ataque: hashes de ficheros, direcciones IP, dominios, URL, nombres de ficheros, claves de registro. Se comparten entre organizaciones y se cargan en las herramientas de detección.

4.2. La pirámide del dolor

No todos los indicadores valen lo mismo. De menos a más costoso de cambiar para el atacante: hashes, direcciones IP, dominios, artefactos de red y de equipo, herramientas y,

arriba del todo, tácticas, técnicas y procedimientos (TTP). Detectar por comportamiento es más difícil, pero mucho más duradero que detectar por hash.

4.3. OSINT para defender

La inteligencia de fuentes abiertas sirve para ver la organización como la ve un atacante:

- **Shodan y Censys:** qué servicios propios están expuestos a Internet (por ejemplo, `org:"Nombre" port:3389`).
- **Google dorks:** documentos y paneles indexados por error (`site:empresa.es filetype:pdf, site:empresa.es intitle:"index of"`).
- **Maltego:** relaciones entre dominios, correos, personas e infraestructuras.
- **Have I Been Pwned:** cuentas corporativas aparecidas en filtraciones.
- **VirusTotal y urlscan.io:** reputación de ficheros, dominios y URL.

Límite legal y ético: consultar información pública es legítimo; interactuar con sistemas ajenos (escanear, probar credenciales, entrar en un panel abierto) sin autorización no lo es. En clase se trabaja solo sobre activos propios o expresamente autorizados.

4.4. Compartir con cuidado: TLP

El protocolo TLP indica hasta dónde puede difundirse una información: TLP:RED (solo los presentes), TLP:AMBER+STRICT (solo la propia organización), TLP:AMBER (organización y clientes que necesiten saberlo), TLP:GREEN (comunidad) y TLP:CLEAR (sin restricción).

5. Detección en la seguridad física

- Control de accesos con registro: tarjetas, biometría, visitas acompañadas.
- Videovigilancia y sensores de movimiento o de apertura en salas técnicas.
- Alarmas ambientales: temperatura, humo, inundación, corte eléctrico.

Los registros físicos también son evidencia: saber quién entró en la sala de servidores a las tres de la madrugada puede resolver una investigación. Lo ideal es integrarlos en el SIEM. La videovigilancia trata datos personales, así que requiere cartel informativo y plazos de conservación limitados.

6. Detección temprana

6.1. Métricas

- **MTTD (tiempo medio de detección):** desde que empieza el incidente hasta que se detecta.
- **MTTR (tiempo medio de respuesta):** desde que se detecta hasta que se resuelve.
- Proporción de falsos positivos y cobertura de fuentes y de técnicas de ATT&CK.

6.2. Qué mejora la detección

- Empezar por pocos casos de uso bien afinados antes que por cientos de reglas sin revisar.
- Relojes sincronizados por NTP en todos los equipos.
- Registros suficientes: lo que no se registra no se puede investigar después.
- Revisar y ajustar las reglas de forma periódica.
- Probar la detección con ataques simulados.

6.3. Un caso

Un viernes por la tarde el SIEM alerta de que un equipo de administración ha lanzado PowerShell codificado y ha contactado con un dominio registrado hace dos días. El analista aísla el equipo desde el EDR en diez minutos. El lunes se confirma que era la fase previa de un ransomware: afectó a un equipo en lugar de a toda la red. La diferencia no fue la herramienta, sino que alguien miraba y sabía qué hacer.

Para ampliar

- Documentación de Wazuh: reglas, decodificadores, FIM y respuesta activa.
- Documentación de Suricata y conjunto de reglas Emerging Threats.
- David J. Bianco: The Pyramid of Pain.
- FIRST: Traffic Light Protocol (TLP) 2.0.
- Guías CCN-STIC sobre detección y herramientas del CCN-CERT.